Module Interface Specification for Flexin'

Team 3, Flexin'
Arjun Karthik
Shao (Daniel) Hu
Noah Goldschmied
Peter DeForest
Daniel Franze-Da Silva

November 12, 2026

1 Revision History

Date	Version	Notes
Date 1	1.0	Notes
Date 2	1.1	Notes

2 Symbols, Abbreviations and Acronyms

See SRS Documentation at [give url —SS]
[Also add any additional symbols, abbreviations or acronyms —SS]

Contents

1 Revision History i

2 Symbols, Abbreviations and Acronyms i

3 Introduction 1

4 Notation 1

5 Module Decomposition 2

6 MIS of Fitness Integration Module 3
- 6.1 Module . . . 3
- 6.2 Uses . . . 3
- 6.3 Syntax . . . 3
  - 6.3.1 Exported Constants . . . 3
  - 6.3.2 Exported Access Programs . . . 4
- 6.4 Semantics . . . 4
  - 6.4.1 State Variables . . . 4
  - 6.4.2 Environment Variables . . . 4
  - 6.4.3 Assumptions . . . 4
  - 6.4.4 Access Routine Semantics . . . 4
  - 6.4.5 Local Functions . . . 4

7 MIS of Persistence Module 4
- 7.1 Module . . . 4
- 7.2 Uses . . . 4
- 7.3 Syntax . . . 5
  - 7.3.1 Exported Constants . . . 5
  - 7.3.2 Exported Access Programs . . . 5

7.4 Semantics . . . 5
7.4.1 State Variables . . . 5
7.4.2 Environment Variables . . . 5
7.4.3 Assumptions . . . 5
7.4.4 Access Routine Semantics . . . 5
7.4.5 Local Functions . . . 5

8 MIS of User and Onboarding Module **5**
8.1 Module . . . 5
8.2 Uses . . . 6
8.3 Syntax . . . 6
8.3.1 Exported Constants . . . 6
8.3.2 Exported Access Programs . . . 6
8.4 Semantics . . . 6
8.4.1 State Variables . . . 6
8.4.2 Environment Variables . . . 6
8.4.3 Assumptions . . . 6
8.4.4 Access Routine Semantics . . . 6
8.4.5 Local Functions . . . 6

9 MIS of Activity Module **6**
9.1 Module . . . 7
9.2 Uses . . . 7
9.3 Syntax . . . 7
9.3.1 Exported Constants . . . 7
9.3.2 Exported Access Programs . . . 7
9.4 Semantics . . . 7
9.4.1 State Variables . . . 7
9.4.2 Environment Variables . . . 7
9.4.3 Assumptions . . . 7
9.4.4 Access Routine Semantics . . . 7
9.4.5 Local Functions . . . 7

10 MIS of Goals Module **8**
10.1 Module . . . 8
10.2 Uses . . . 8
10.3 Syntax . . . 8
10.3.1 Exported Constants . . . 8
10.3.2 Exported Access Programs . . . 8
10.4 Semantics . . . 8
10.4.1 State Variables . . . 8
10.4.2 Environment Variables . . . 8
10.4.3 Assumptions . . . 8

10.4.4 Access Routine Semantics . . . 8
10.4.5 Local Functions . . . 9

11 MIS of Currency Ledger Module **9**
11.1 Module . . . 9
11.2 Uses . . . 9
11.3 Syntax . . . 9
11.3.1 Exported Constants . . . 9
11.3.2 Exported Access Programs . . . 9
11.4 Semantics . . . 9
11.4.1 State Variables . . . 9
11.4.2 Environment Variables . . . 9
11.4.3 Assumptions . . . 9
11.4.4 Access Routine Semantics . . . 10
11.4.5 Local Functions . . . 10

12 MIS of Asset Module **10**
12.1 Module . . . 10
12.2 Uses . . . 10
12.3 Syntax . . . 10
12.3.1 Exported Constants . . . 10
12.3.2 Exported Access Programs . . . 10
12.4 Semantics . . . 10
12.4.1 State Variables . . . 10
12.4.2 Environment Variables . . . 11
12.4.3 Assumptions . . . 11
12.4.4 Access Routine Semantics . . . 11
12.4.5 Local Functions . . . 11

13 MIS of Transaction Order Module **11**
13.1 Module . . . 11
13.2 Uses . . . 11
13.3 Syntax . . . 11
13.3.1 Exported Constants . . . 11
13.3.2 Exported Access Programs . . . 11
13.4 Semantics . . . 12
13.4.1 State Variables . . . 12
13.4.2 Environment Variables . . . 12
13.4.3 Assumptions . . . 12
13.4.4 Access Routine Semantics . . . 12
13.4.5 Local Functions . . . 12

14 MIS of Portfolio Module **12**
14.1 Module . . . 12
14.2 Uses . . . 12
14.3 Syntax . . . 12
14.3.1 Exported Constants . . . 12
14.3.2 Exported Access Programs . . . 13
14.4 Semantics . . . 13
14.4.1 State Variables . . . 13
14.4.2 Environment Variables . . . 13
14.4.3 Assumptions . . . 13
14.4.4 Access Routine Semantics . . . 13
14.4.5 Local Functions . . . 13

15 MIS of Leaderboard and Friends Module **13**
15.1 Module . . . 13
15.2 Uses . . . 13
15.3 Syntax . . . 14
15.3.1 Exported Constants . . . 14
15.3.2 Exported Access Programs . . . 14
15.4 Semantics . . . 14
15.4.1 State Variables . . . 14
15.4.2 Environment Variables . . . 14
15.4.3 Assumptions . . . 14
15.4.4 Access Routine Semantics . . . 14
15.4.5 Local Functions . . . 14

16 MIS of Progress Reporting Module **14**
16.1 Module . . . 14
16.2 Uses . . . 15
16.3 Syntax . . . 15
16.3.1 Exported Constants . . . 15
16.3.2 Exported Access Programs . . . 15
16.4 Semantics . . . 15
16.4.1 State Variables . . . 15
16.4.2 Environment Variables . . . 15
16.4.3 Assumptions . . . 15
16.4.4 Access Routine Semantics . . . 15
16.4.5 Local Functions . . . 15

17 MIS of UI Screens Module **15**
17.1 Module . . . 16
17.2 Uses . . . 16
17.3 Syntax . . . 16

17.3.1 Exported Constants . . . 16
17.3.2 Exported Access Programs . . . 16
17.4 Semantics . . . 16
17.4.1 State Variables . . . 16
17.4.2 Environment Variables . . . 16
17.4.3 Assumptions . . . 16
17.4.4 Access Routine Semantics . . . 16
17.4.5 Local Functions . . . 16

18 MIS of Notification Module **17**
18.1 Module . . . 17
18.2 Uses . . . 17
18.3 Syntax . . . 17
18.3.1 Exported Constants . . . 17
18.3.2 Exported Access Programs . . . 17
18.4 Semantics . . . 17
18.4.1 State Variables . . . 17
18.4.2 Environment Variables . . . 17
18.4.3 Assumptions . . . 17
18.4.4 Access Routine Semantics . . . 17
18.4.5 Local Functions . . . 18

19 MIS of Market Simulation Module **19**
19.1 Module . . . 19
19.2 Uses . . . 19
19.3 Syntax . . . 19
19.3.1 Exported Constants . . . 19
19.3.2 Exported Types . . . 20
19.3.3 Exported Access Programs . . . 20
19.4 Semantics . . . 21
19.4.1 State Variables . . . 21
19.4.2 Environment Variables . . . 21
19.4.3 Assumptions . . . 22
19.4.4 Access Routine Semantics . . . 22
19.4.5 Local Functions . . . 24

20 MIS of API Client Module **26**
20.1 Module . . . 26
20.2 Uses . . . 26
20.3 Syntax . . . 26
20.3.1 Exported Constants . . . 26
20.3.2 Exported Types . . . 27
20.3.3 Exported Access Programs . . . 27

20.4 Semantics . . . 28
20.4.1 State Variables . . . 28
20.4.2 Environment Variables . . . 29
20.4.3 Assumptions . . . 29
20.4.4 Access Routine Semantics . . . 29
20.4.5 Local Functions . . . 31

21 MIS of Authentication and Security Module **32**
21.1 Module . . . 32
21.2 Uses . . . 32
21.3 Syntax . . . 32
21.3.1 Exported Constants . . . 32
21.3.2 Exported Types . . . 32
21.3.3 Exported Access Programs . . . 33
21.4 Semantics . . . 34
21.4.1 State Variables . . . 34
21.4.2 Environment Variables . . . 34
21.4.3 Assumptions . . . 35
21.4.4 Access Routine Semantics . . . 35
21.4.5 Local Functions . . . 38

22 Appendix — Generative AI Use Disclosure **39**
22.1 AI Tools Used . . . 39
22.2 How and Where Used . . . 39
22.3 Verification of AI-Generated Content . . . 40

23 Appendix — Reflection **40**

3 Introduction

The following document details the Module Interface Specifications for [Fill in your project name and description —SS]

Complementary documents include the System Requirement Specifications and Module Guide. The full documentation and implementation can be found at .... [provide the url for your repo —SS]

4 Notation

[You should describe your notation. You can use what is below as a starting point. —SS]

The structure of the MIS for modules comes from **?**, with the addition that template modules have been adapted from **?**. The mathematical notation comes from Chapter 3 of

?. For instance, the symbol := is used for a multiple assignment statement and conditional rules follow the form $(c_1 \Rightarrow r_1 | c_2 \Rightarrow r_2 | ... | c_n \Rightarrow r_n)$.

The following table summarizes the primitive data types used by Flexin'.

Data Type	**Notation**	**Description**
character	char	a single symbol or digit
integer	$\mathbb{Z}$	a number without a fractional component in (-∞, ∞)
natural number	$\mathbb{N}$	a number without a fractional component in [1, ∞)
real	$\mathbb{R}$	any number in (-∞, ∞)

The specification of Flexin' uses some derived data types: sequences, strings, and tuples. Sequences are lists filled with elements of the same data type. Strings are sequences of characters. Tuples contain a list of values, potentially of different types. In addition, Flexin' uses functions, which are defined by the data types of their inputs and outputs. Local functions are described by giving their type signature followed by their specification.

5 Module Decomposition

The following table is taken directly from the Module Guide document for this project.

Level 1	Level 2
Hardware-Hiding Module	Fitness Integration Module
Behaviour-Hiding Module	Persistence Module User and Onboarding Module Activity Module Goals Module Currency Ledger Module Asset Module Transaction Order Module Portfolio Module Leaderboard and Friends Module Progress Reporting Module UI Screens Module Notification Module Market Simulation Module API Client Module
Software Decision Module	Authentication and Security Module

Table 1: Module Hierarchy

6 MIS of Fitness Integration Module

This module is M1 in the Module Guide.

6.1 Module

FitnessIntegration

6.2 Uses

[Modules this module uses —SS]

6.3 Syntax

6.3.1 Exported Constants

[Exported constants, or None —SS]

6.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

6.4 Semantics

6.4.1 State Variables

[State variables, or None —SS]

6.4.2 Environment Variables

[Environment variables, or None —SS]

6.4.3 Assumptions

[Assumptions, or None —SS]

6.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

6.4.5 Local Functions

[Local functions, or None —SS]

7 MIS of Persistence Module

This module is M2 in the Module Guide.

7.1 Module

Persistence

7.2 Uses

[Modules this module uses —SS]

7.3 Syntax

7.3.1 Exported Constants

[Exported constants, or None —SS]

7.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

7.4 Semantics

7.4.1 State Variables

[State variables, or None —SS]

7.4.2 Environment Variables

[Environment variables, or None —SS]

7.4.3 Assumptions

[Assumptions, or None —SS]

7.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

7.4.5 Local Functions

[Local functions, or None —SS]

8 MIS of User and Onboarding Module

This module is M3 in the Module Guide.

8.1 Module

User

8.2 Uses

[Modules this module uses —SS]

8.3 Syntax

8.3.1 Exported Constants

[Exported constants, or None —SS]

8.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

8.4 Semantics

8.4.1 State Variables

[State variables, or None —SS]

8.4.2 Environment Variables

[Environment variables, or None —SS]

8.4.3 Assumptions

[Assumptions, or None —SS]

8.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

8.4.5 Local Functions

[Local functions, or None —SS]

9 MIS of Activity Module

This module is M4 in the Module Guide.

9.1 Module

Activity

9.2 Uses

[Modules this module uses —SS]

9.3 Syntax

9.3.1 Exported Constants

[Exported constants, or None —SS]

9.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

9.4 Semantics

9.4.1 State Variables

[State variables, or None —SS]

9.4.2 Environment Variables

[Environment variables, or None —SS]

9.4.3 Assumptions

[Assumptions, or None —SS]

9.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

9.4.5 Local Functions

[Local functions, or None —SS]

10 MIS of Goals Module

This module is M5 in the Module Guide.

10.1 Module

Goals

10.2 Uses

[Modules this module uses —SS]

10.3 Syntax

10.3.1 Exported Constants

[Exported constants, or None —SS]

10.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

10.4 Semantics

10.4.1 State Variables

[State variables, or None —SS]

10.4.2 Environment Variables

[Environment variables, or None —SS]

10.4.3 Assumptions

[Assumptions, or None —SS]

10.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

10.4.5 Local Functions

[Local functions, or None —SS]

11 MIS of Currency Ledger Module

This module is M6 in the Module Guide.

11.1 Module

CurrencyLedger

11.2 Uses

[Modules this module uses —SS]

11.3 Syntax

11.3.1 Exported Constants

[Exported constants, or None —SS]

11.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

11.4 Semantics

11.4.1 State Variables

[State variables, or None —SS]

11.4.2 Environment Variables

[Environment variables, or None —SS]

11.4.3 Assumptions

[Assumptions, or None —SS]

11.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

11.4.5 Local Functions

[Local functions, or None —SS]

12 MIS of Asset Module

This module is M7 in the Module Guide.

12.1 Module

Asset

12.2 Uses

[Modules this module uses —SS]

12.3 Syntax

12.3.1 Exported Constants

[Exported constants, or None —SS]

12.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

12.4 Semantics

12.4.1 State Variables

[State variables, or None —SS]

12.4.2 Environment Variables

[Environment variables, or None —SS]

12.4.3 Assumptions

[Assumptions, or None —SS]

12.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

12.4.5 Local Functions

[Local functions, or None —SS]

13 MIS of Transaction Order Module

This module is M8 in the Module Guide.

13.1 Module

TransactionOrder

13.2 Uses

[Modules this module uses —SS]

13.3 Syntax

13.3.1 Exported Constants

[Exported constants, or None —SS]

13.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

13.4 Semantics

13.4.1 State Variables

[State variables, or None —SS]

13.4.2 Environment Variables

[Environment variables, or None —SS]

13.4.3 Assumptions

[Assumptions, or None —SS]

13.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

13.4.5 Local Functions

[Local functions, or None —SS]

14 MIS of Portfolio Module

This module is M9 in the Module Guide.

14.1 Module

Portfolio

14.2 Uses

[Modules this module uses —SS]

14.3 Syntax

14.3.1 Exported Constants

[Exported constants, or None —SS]

14.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

14.4 Semantics

14.4.1 State Variables

[State variables, or None —SS]

14.4.2 Environment Variables

[Environment variables, or None —SS]

14.4.3 Assumptions

[Assumptions, or None —SS]

14.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

14.4.5 Local Functions

[Local functions, or None —SS]

15 MIS of Leaderboard and Friends Module

This module is M10 in the Module Guide.

15.1 Module

Leaderboard

15.2 Uses

[Modules this module uses —SS]

15.3 Syntax

15.3.1 Exported Constants

[Exported constants, or None —SS]

15.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

15.4 Semantics

15.4.1 State Variables

[State variables, or None —SS]

15.4.2 Environment Variables

[Environment variables, or None —SS]

15.4.3 Assumptions

[Assumptions, or None —SS]

15.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

15.4.5 Local Functions

[Local functions, or None —SS]

16 MIS of Progress Reporting Module

This module is M11 in the Module Guide.

16.1 Module

ProgressReport

16.2 Uses

[Modules this module uses —SS]

16.3 Syntax

16.3.1 Exported Constants

[Exported constants, or None —SS]

16.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

16.4 Semantics

16.4.1 State Variables

[State variables, or None —SS]

16.4.2 Environment Variables

[Environment variables, or None —SS]

16.4.3 Assumptions

[Assumptions, or None —SS]

16.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

16.4.5 Local Functions

[Local functions, or None —SS]

17 MIS of UI Screens Module

This module is M12 in the Module Guide.

17.1 Module

UIScreens

17.2 Uses

[Modules this module uses —SS]

17.3 Syntax

17.3.1 Exported Constants

[Exported constants, or None —SS]

17.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

17.4 Semantics

17.4.1 State Variables

[State variables, or None —SS]

17.4.2 Environment Variables

[Environment variables, or None —SS]

17.4.3 Assumptions

[Assumptions, or None —SS]

17.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

17.4.5 Local Functions

[Local functions, or None —SS]

18 MIS of Notification Module

This module is M13 in the Module Guide.

18.1 Module

Notification

18.2 Uses

[Modules this module uses —SS]

18.3 Syntax

18.3.1 Exported Constants

[Exported constants, or None —SS]

18.3.2 Exported Access Programs

Name	In	Out	Exceptions
[accessProg —SS]	-	-	-

18.4 Semantics

18.4.1 State Variables

[State variables, or None —SS]

18.4.2 Environment Variables

[Environment variables, or None —SS]

18.4.3 Assumptions

[Assumptions, or None —SS]

18.4.4 Access Routine Semantics

[accessProg —SS]():

- transition: [if appropriate —SS]
- output: [if appropriate —SS]
- exception: [if appropriate —SS]

18.4.5 Local Functions

[Local functions, or None —SS]

19 MIS of Market Simulation Module

This module is M14 in the Module Guide.

19.1 Module

MarketSimulation

19.2 Uses

- Asset Module (Section 12): the list of assets, and each asset's type, starting price and annual dividend yield.
- Currency Ledger Module (Section 11): credits dividend payouts to users' balances.
- Persistence Module (Section 7): stores prices, price history, market events and dividend payouts, and reads the holdings of an asset when a dividend is announced.
- Authentication and Security Module (Section 21): the Time and UserID types.

Holdings are read through the Persistence Module rather than the Portfolio Module, because the Portfolio Module uses this module to value holdings and using it here would create a cycle in the uses hierarchy.

19.3 Syntax

19.3.1 Exported Constants

None. The module uses the following local constants, which are not exported.

Constant	Value	Meaning
TickInterval	15 minutes	Time between scheduled price updates
MinPrice	0.01 FLX	Lowest price an asset can have
DividendInterval	YearLength / 4	Time between an asset's dividend payments (91.3125 days)
YearLength	365.25 days	Length of a year, used to express elapsed time in years

Durations are converted to seconds, the unit of Time, wherever they are combined with a Time. The *step* inputs of getHistory and getTypeTrend are also durations in seconds.

19.3.2 Exported Types

- AssetID and AssetType: as defined by the Asset Module (Section 12), with AssetType = {STOCK, BOND, ETF, FUND}
- UserID and Time: as defined in Section 21
- Amount: a decimal number with exactly two decimal places, in FLX
- Price: an Amount that is at least MinPrice
- PricePoint = tuple of (*asset*: AssetID, *time*: Time, *price*: Price)
- TrendPoint = tuple of (*time*: Time, *value*: $\mathbb{R}$)
- EventKind = {SHOCK, DIVIDEND}
- MarketEvent = tuple of (*id*: $\mathbb{N}$, *time*: Time, *kind*: EventKind, *scope*: AssetID $\cup$ {MARKET}, *magnitude*: $\mathbb{R}$, *description*: String). For a SHOCK, *scope* is MARKET and *magnitude* is the fractional price change of the whole market (negative for a downturn). For a DIVIDEND, *scope* is the asset paying it and *magnitude* is the Amount paid per unit held.

19.3.3 Exported Access Programs

Name	In	Out	Exceptions
init	-	-	-
getPrice	*a*: AssetID	PricePoint	UnknownAsset, NoPrice
getPrices	-	sequence of PricePoint	-
getPriceAt	*a*: AssetID, *t*: Time	PricePoint	UnknownAsset, NoPrice
getHistory	*a*: AssetID, *from*: Time, *to*: Time, *step*: $\mathbb{R}$	sequence of PricePoint	UnknownAsset, InvalidRange
getTypeTrend	*y*: AssetType, *from*: Time, *to*: Time, *step*: $\mathbb{R}$	sequence of TrendPoint	InvalidRange
getEvents	*from*: Time, *to*: Time	sequence of MarketEvent	InvalidRange
tick	-	-	-
backfill	*a*: AssetID, *from*: Time	-	UnknownAsset, AlreadyPriced, InvalidRange

19.4 Semantics

19.4.1 State Variables

- *level*: AssetID $\to \mathbb{R}$, the unrounded price of each asset used by the price model
- *price*: AssetID $\to$ Price, the published price of each asset
- *history*: sequence of PricePoint, every published price in time order. Entries are only ever appended.
- *typeIndex*: AssetType $\to \mathbb{R}$, an index of each asset type's overall price movement
- *trends*: sequence of tuples of (*type*: AssetType, *point*: TrendPoint), every value of *typeIndex* in time order. Entries are only ever appended.
- *events*: sequence of MarketEvent, in time order. Entries are only ever appended.
- *payouts*: set of tuples of (*event*: $\mathbb{N}$, *user*: UserID, *amount*: Amount, *paid*: $\mathbb{B}$), the dividend owed to each holder for each DIVIDEND event
- *lastDividend*: AssetID $\to$ Time, when each asset last paid a dividend
- *lastTick*: Time $\cup\{\perp\}$, when prices were last updated

When the system is first deployed, *level*, *price* and *lastDividend* have no entries, *history*, *trends* and *events* are empty, *payouts* $= \emptyset$, $typeIndex(y) = 100$ for every AssetType y, and $lastTick = \perp$.
All state variables are stored through the Persistence Module, so they keep their values when the backend restarts. *history* and *events* together form the audit record of market price updates and dividends required by SEC-AUD-01.

19.4.2 Environment Variables

- *clock*: the system clock; *now*() returns the current Time.
- *rng*: a source of random numbers, seeded from the backend configuration.
- *scheduler*: calls tick once every TickInterval.
- *calibration*: the price model's parameters, read from a configuration file. For each AssetType y it gives the annual total return μ_y, the annual volatility σ_y, the correlation ρ_y^m with the whole market, the correlation ρ_y^t with other assets of type y, and the sensitivity β_y to market-wide downturns. It also gives *ShockRate*, the expected number of downturns per year, and *ShockSize*, the distribution of their size. The parameters are derived from historical market data that is free to use in an educational application (PR-PA-06).

- *log*: the backend log, to which failed updates are written.

Tests may supply their own *clock* and a fixed seed for *rng*, so that many simulated years can be run in seconds and repeated exactly (test-PR-PA-06). Setting $\sigma_y = 0$, $\mu_y = 0$ and $ShockRate = 0$ keeps prices fixed for tests that need known prices.

19.4.3 Assumptions

- init is called once when the backend starts, before any other access program and before the scheduler first calls tick.
- Every asset defined by the Asset Module has a type, a starting price of at least MinPrice, and an annual dividend yield of at least 0.
- The number of units of an asset that a user holds is a natural number.
- For every AssetType y, $(\rho_y^m)^2 + (\rho_y^t)^2 \leq 1$.
- A single backend instance runs the scheduler, so tick is never run twice at the same time.
- ETFs and funds are priced independently, with their own calibration parameters, rather than from the assets they hold.

19.4.4 Access Routine Semantics

Simulated time runs at the same rate as real time: one simulated year of price movement takes one real year. Every access program that reads state sees the state left by the most recent completed tick.

init():

- transition: ($lastTick = \perp \Rightarrow lastTick := now() \mid lastTick \neq \perp \Rightarrow$ no change)

On first deployment, init starts simulated time. After a restart, the stored state is used unchanged, and the next tick covers the whole time since *lastTick*.

getPrice(a):

- output: *out* := the last entry in *history* whose *asset* is a
- exception: a is not an asset $\Rightarrow$ UnknownAsset | a has no entry in *history* $\Rightarrow$ NoPrice

getPrices():

- output: *out* := getPrice(a) for every asset a that has an entry in *history*

getPriceAt(a, t):

- output: *out* := the last entry in *history* whose *asset* is a and whose *time* is at most t, that is, the price in effect at time t
- exception: a is not an asset $\Rightarrow$ UnknownAsset | no such entry exists $\Rightarrow$ NoPrice

getHistory($a, from, to, step$):

- output: *out* := getPriceAt($a, from + k \cdot step$) for $k = 0, 1, 2, \ldots$ while $from + k \cdot step \leq to$, leaving out any time before a's first price
- exception: a is not an asset $\Rightarrow$ UnknownAsset | $from > to \vee step \leq 0 \Rightarrow$ InvalidRange

getTypeTrend($y, from, to, step$):

- output: *out* := for $k = 0, 1, 2, \ldots$ while $from + k \cdot step \leq to$, the last TrendPoint in *trends* for type y whose *time* is at most $from + k \cdot step$, leaving out any time before the first one
- exception: $from > to \vee step \leq 0 \Rightarrow$ InvalidRange

getEvents($from, to$):

- output: *out* := the entries e of *events* with $from \leq e.time \leq to$, in time order
- exception: $from > to \Rightarrow$ InvalidRange

tick():

- Let $n = now()$ and $\Delta t = (n - lastTick)/\mathsf{YearLength}$, the time since the last update in years.
- transition, part 1 (prices, events and dividend announcements). Steps 1 to 5 take effect together or not at all.
    1. Downturn: with probability $1 - e^{-ShockRate \cdot \Delta t}$, a SHOCK event with scope MARKET and magnitude J drawn from *ShockSize* is appended to *events*. Otherwise $J = 0$. This is the probability that at least one downturn occurs within Δt when downturns arrive at random at an average rate of *ShockRate* per year, as in the jump model of **?**.
    2. Prices: one market draw Z_m, one draw Z_y for each AssetType y and one draw Z_a for each asset a are taken with *drawNormal*. For each asset a of type y that already has a price, $level(a) := level(a) \cdot e^{logReturn(a, \Delta t, Z_m, Z_y, Z_a)} \cdot (1 + \beta_y J)$. An asset with no price yet starts with $level(a) := startPrice(a)$ and $lastDividend(a) := n$. Then $price(a) := \max(\mathsf{MinPrice}, round_2(level(a)))$ and $(a, n, price(a))$ is appended to *history*.

3. Type trends: for each AssetType y with at least one priced asset, $typeIndex(y)$ is multiplied by the average, over the assets of type y priced in step 2, of $level(a)$ after the step divided by $level(a)$ before it. $(y, (n, typeIndex(y)))$ is appended to *trends*.
4. Dividend announcements: for each asset a with $yield(a) > 0$ whose last dividend, at $lastDividend(a)$, was at least DividendInterval before n, let f be DividendInterval in years (here $\frac{1}{4}$) and $d = round_2(price(a) \cdot yield(a) \cdot f)$, the amount paid per unit. If $d \geq 0.01$, a DIVIDEND event e with scope a and magnitude d is appended to *events*, and for every $(u, q) \in holdings(a)$ with $q > 0$, $(e.id, u, q \cdot d, \text{false})$ is added to *payouts*. In either case $lastDividend(a) := n$.
5. $lastTick := n$.

If any of steps 1 to 5 fails, the state is unchanged and the failure is written to *log*. The last valid prices stay in effect, and the next tick covers the whole time since *lastTick* (BUC 6).

- transition, part 2 (dividend payouts): for each $p \in payouts$ with $\neg p.paid$, $p.amount$ is credited to $p.user$ through the Currency Ledger Module, citing event $p.event$ as its source, and $p.paid := \text{true}$. Each payout's credit and its change to *paid* take effect together or not at all. A payout that fails stays unpaid and is retried at the next tick, so each payout is credited exactly once.

backfill($a, from$):

- transition: $level(a) := startPrice(a)$. Then, for each time $t = from + k \cdot$ TickInterval with $k = 1, 2, \ldots$ and $t \leq now()$, $level(a)$ is updated as in step 2 of tick with $\Delta t =$ TickInterval/YearLength and J drawn as in step 1 of tick, and $(a, t, price(a))$ is appended to *history*. Finally $lastDividend(a) := now()$. No events or payouts are created.

- exception: a is not an asset $\Rightarrow$ UnknownAsset | a has an entry in *history* $\Rightarrow$ AlreadyPriced | $from \geq now() \Rightarrow$ InvalidRange

backfill gives a newly listed asset a price history, and is used by the demonstration data script (TRN-03).

19.4.5 Local Functions

- *type*: AssetID $\to$ AssetType, *startPrice*: AssetID $\to$ Price, and *yield*: AssetID $\to \mathbb{R}$
  The asset's type, starting price and annual dividend yield, read from the Asset Module.

- *holdings*: AssetID $\to$ set of (UserID $\times \mathbb{N}$)
  $holdings(a) \equiv$ each user holding asset a and the number of units they hold, read through the Persistence Module.

- $round_2$: $\mathbb{R} \to$ Amount
  $round_2(x) \equiv x$ rounded to two decimal places, with ties rounded to the even digit.

- *drawNormal*: $\to \mathbb{R}$
  A random number from the standard normal distribution, taken from *rng*.

- *logReturn*: AssetID $\times\mathbb{R} \times \mathbb{R} \times \mathbb{R} \times \mathbb{R} \to \mathbb{R}$
  For an asset a of type y with $q = \mathit{yield}(a)$:

$$\mathit{logReturn}(a, \Delta t, Z_m, Z_y, Z_a) \equiv \left(\mu_y - q - \lambda\kappa_y - \frac{\sigma_y^2}{2}\right)\Delta t + \sigma_y\sqrt{\Delta t}\, W$$

  where $\lambda = \mathit{ShockRate}$, $\kappa_y = \beta_y \cdot E[J]$ with $E[J]$ the mean of *ShockSize*, and W combines the market, type and asset draws:

$$W = \rho_y^m Z_m + \rho_y^t Z_y + \sqrt{1 - (\rho_y^m)^2 - (\rho_y^t)^2}\, Z_a$$

  This is geometric Brownian motion, the standard model of stock price movement (**??**). The yield is subtracted from the drift so that an asset's price growth plus its dividends matches the calibrated total return μ_y, following the treatment of continuous dividend yields in **?**. W splits each asset's random movement into a part shared by the whole market, a part shared by its asset type and a part of its own, extending the single-index model of **?**. The square root keeps the variance of W at 1, so σ_y remains the asset's volatility. Market-wide downturns are added as jumps in tick. They occur λ times a year on average and change a type-y asset's price by κ_y each time on average ($\kappa_y < 0$), so the term $\lambda\kappa_y$ raises the drift by the same amount and keeps the expected total return at μ_y, as in the jump model of **?**.

20 MIS of API Client Module

This module is M15 in the Module Guide.

20.1 Module

ApiClient

20.2 Uses

This module runs on the phone, and mobile modules reach the backend only through it. It uses every backend module whose access programs a user of the app can request, together with those programs' types and exceptions:

- User and Onboarding Module (Section 8)
- Activity Module (Section 9)
- Goals Module (Section 10)
- Currency Ledger Module (Section 11)
- Asset Module (Section 12)
- Transaction Order Module (Section 13)
- Portfolio Module (Section 14)
- Leaderboard and Friends Module (Section 15)
- Progress Reporting Module (Section 16)
- Notification Module (Section 18)
- Market Simulation Module (Section 19)
- Authentication and Security Module (Section 21), which also provides the session renewal this module performs on its own

20.3 Syntax

20.3.1 Exported Constants

None. The module uses the following local constants, which are not exported.

Constant	Value	Meaning
RequestTimeout	10 seconds	Time after which a request with no response counts as failed
MaxRetries	2	Number of times a failed request is sent again
RetryBaseDelay	0.5 seconds	Wait before the first retry; the wait doubles for each further retry

20.3.2 Exported Types

The inputs and outputs of the exported programs use the types defined in the sections of the backend modules listed under Uses. In addition:

- Time, DeviceID, Token and MfaChallenge: as defined in Section 21
- SignInOutcome = {SIGNED_IN}∪ MfaChallenge
- For any type T, Fresh(T) = tuple of (*data*: T, *receivedAt*: Time, *stale*: $\mathbb{B}$). A result of this type is returned by every program that only reads data. *stale* is true when *data* is a stored copy rather than a response just received from the backend, so it may be out of date.
- ReadOp: the set of exported programs that only read data

20.3.3 Exported Access Programs

For each access program of a backend module listed under Uses, this module exports an access program with the same name, unless it is one of the backend-only programs listed below or is specified individually in the table. Its inputs are the backend program's inputs without the Principal, the client IP address and the DeviceID, which this module supplies itself. Its output is the backend program's output, wrapped in Fresh if the program only reads data. Its exceptions are the backend program's exceptions plus the transport exceptions listed below.

The following backend programs are not exported by this module. All but refresh are used only within the backend; refresh is requested by this module itself to renew the session (rule 2 below). When the section of another backend module defines a program of this kind, it is added here.

Backend Module	Programs Not Exported
Market Simulation	init, tick, backfill
Authentication and Security	init, hashPassword, authenticate, authorize, requireRole, confirmPassword, refresh, endAllSessions

The following programs are specified individually, because they keep the session and stored data on the phone or differ from the backend program of the same name.

Name	In	Out	Exceptions
init	-	-	-
signIn	*email*: String, *pw*: String	SignInOutcome	UnknownAccount, AccountLocked, InvalidCredentials
verifyMfa	*cid*: Token, *code*: String	-	InvalidCode
signOut	-	-	-
isSignedIn	-	$\mathbb{B}$	-
peek	*op*: ReadOp, *args*: the inputs of *op*	Fresh(T) $\cup\{\bot\}$, where T is the data type of *op*'s output	-

In addition to their other exceptions, signIn, verifyMfa and every program exported by the rule above may raise the following transport exceptions:

- NetworkError: the backend could not be reached, and no stored copy of the requested data is available.
- ServerError: the backend failed because of a fault of its own.
- RateLimited: the backend refused the request because too many requests were made; it carries the time to wait before trying again.
- SessionExpired: the program needs a signed-in user and the session could not be renewed, so the user must sign in again. Raised only by programs whose backend program needs an authenticated user; the assumptions of Section 21 list the requests that do not.

20.4 Semantics

20.4.1 State Variables

- *deviceId*: DeviceID, created once for this installation
- *accessToken*: Token $\cup\{\bot\}$, the current access token, held in memory only
- *refreshToken*: Token $\cup\{\bot\}$, the current refresh token, held in *secureStore*
- *cache*: (ReadOp $\times$ inputs) $\to$ (data, Time), the last data received for each read and when it was received, held in *localStore*
- *renewing*: $\mathbb{B}$, true while a session renewal is in progress

20.4.2 Environment Variables

- *backend*: the backend service, reached over the network at the address given in the app's build configuration.
- *secureStore*: encrypted storage on the device that other apps cannot read.
- *localStore*: storage on the device that is private to the app.
- *clock*: the device clock; *now*() returns the current Time.

20.4.3 Assumptions

- init is called once, when the app starts, before any other access program.
- In release builds the backend is reached only over TLS 1.3 (SEC-PRV-01), and a backend address that does not use it is refused.
- The backend treats requests that carry the same request key as one request: it performs the action once and returns the same result for each.
- Only one user is signed in on an installation at a time.
- Amounts and prices are received as exact decimal values, and this module never converts them to floating-point numbers (PR-PA-01). The backend calculates all amounts and prices (SEC-INT-02).

20.4.4 Access Routine Semantics

Every request to the backend follows these rules.

1. Credentials: a request for a program that needs a signed-in user carries *accessToken*. Every request carries *deviceId*.
2. Renewal: if the backend rejects a request with Unauthenticated, the session is renewed by requesting the backend's refresh with *refreshToken*. Requests rejected while *renewing* is true wait for that renewal instead of starting another, because each renewal replaces the refresh token. The renewal ends in one of three ways:
    - refresh returns a TokenPair $r \Rightarrow$ *accessToken* := *r.access* and *refreshToken* := *r.refresh*, the new refresh token is stored in *secureStore*, and the request is sent again once.
    - refresh raises Unauthenticated, or there is no refresh token $\Rightarrow$ both tokens are set to $\perp$, *cache* := $\emptyset$, and SessionExpired is raised.
    - refresh gets no response or the backend reports a fault of its own $\Rightarrow$ the tokens and *cache* are unchanged, and the request counts as failed: a read falls back as in rule 3, and a write raises NetworkError or ServerError.

3. Reads: if the backend gives no response within RequestTimeout or reports a fault of its own, the request is sent again up to MaxRetries times, waiting $backoff(k)$ before retry k. When data d is received, $cache(op, args) := (d, now())$ if $cacheable(op)$, and the output is $(d, now(), \text{false})$. If every attempt fails: ($cache(op, args)$ exists $\Rightarrow$ its data and time with $stale$ = true | otherwise $\Rightarrow$ NetworkError or ServerError). This keeps the app usable with the last data received when the backend cannot be reached (PR-RFT-04).

4. Writes: each call creates a new request key with $newRequestKey$, and every retry of that call reuses it. Retries follow rule 3, so a write whose response was lost takes effect only once (PR-RFT-02). A write that fails is never stored to be sent later.

5. RateLimited is raised as soon as it is received, with the wait time given by the backend, and the request is not retried.

6. Any other exception from the backend is raised under the same name.

init():

- transition:
  - $deviceId$:= the DeviceID held in $secureStore$. If there is none, a new one is created with $newDeviceId()$ and stored in $secureStore$.
  - $refreshToken$:= the token held in $secureStore$, or $\perp$ if there is none.
  - $accessToken := \perp$.

signIn($email, pw$):

- transition: if the backend returns a TokenPair r, then $accessToken := r.access$, and $refreshToken := r.refresh$ is stored in $secureStore$.
- output: out := (the backend returns a TokenPair $\Rightarrow$ SIGNED_IN | the backend returns an MfaChallenge $c \Rightarrow c$)
- exception: the backend's exceptions, as in Section 21

verifyMfa($cid, code$):

- transition: $accessToken$ and $refreshToken$ are set from the returned TokenPair, as in signIn
- exception: the backend's exceptions, as in Section 21

signOut():

- transition: the backend's signOut is requested once and its result is ignored. Then $accessToken, refreshToken := \perp, \perp$, the refresh token is removed from $secureStore$, and $cache := \emptyset$. The device is signed out even when the backend cannot be reached.

isSignedIn():

- output: $out := refreshToken \neq \bot$

Every program $X(args)$ exported by the rule:

- transition and output: the backend program X is requested with *args*. If X only reads data, the request is a read and *out* is given by rule 3. Otherwise the request is a write (rule 4), and *out* is the backend program's output.
- exception: the exceptions of the backend program X, as given in its module's section, and the transport exceptions

peek(op, *args*):

- output: $out := (cache(op, args)$ exists $\Rightarrow$ its data and time with $stale = \text{true} \mid \text{otherwise} \Rightarrow \bot)$

peek sends no request. It lets a screen show the last data received as soon as the app opens, while it requests current data with *op* (PR-SL-01).

20.4.5 Local Functions

- *backoff*: $\mathbb{N} \to \mathbb{R}$
  $backoff(k) \equiv \mathsf{RetryBaseDelay} \cdot 2^{k-1}$ seconds
- *cacheable*: ReadOp $\to \mathbb{B}$
  $cacheable(op) \equiv$ the output of *op* contains no profile details and no health or fitness data, which must be encrypted when stored (SEC-PRV-01). Other data, such as balances, holdings and prices, is cached.
- *newRequestKey*: $\to$ String
  A random value that has not been used before.
- *newDeviceId*: $\to$ DeviceID
  A random value that identifies this installation.

21 MIS of Authentication and Security Module

This module is M16 in the Module Guide.

21.1 Module

Auth

21.2 Uses

- Persistence Module (Section 7): stores user records, sessions, sign-in lockout state, multi-factor authentication challenges and password reset tokens.

Auth runs on the backend only. Storing tokens on the phone and attaching them to requests is the responsibility of the API Client Module (Section 20).

21.3 Syntax

21.3.1 Exported Constants

The following constants are defined in the SRS.

Constant	Value	SRS Requirement
AccessExpiry	60 minutes	SEC-ACC-01
SessionTimeout	30 days without use	SEC-ACC-05
MinPasswordLength	8 characters	SEC-ACC-04
LockoutAttempts	5 consecutive failures	SEC-ACC-04
LockoutDuration	15 minutes	SEC-ACC-04
RateLimit	60 requests per minute	SEC-IMM-02

Two further constants are local to this module and are not exported: MfaCodeExpiry = 10 minutes, the time a multi-factor authentication code remains valid, and ResetTokenExpiry = 30 minutes, the time a password reset link remains valid.

21.3.2 Exported Types

- UserID = $\mathbb{N}$
- SessionID = $\mathbb{N}$
- DeviceID = String, an identifier the client generates when the app is installed
- Token = String

- Time = $\mathbb{R}$, seconds since the Unix epoch
- Role = $\{\text{STANDARD}, \text{ADMIN}\}$
- Principal = tuple of (*user*: UserID, *role*: Role, *session*: SessionID, *device*: DeviceID)
- TokenPair = tuple of (*access*: Token, *refresh*: Token, *accessExpires*: Time)
- MfaChallenge = tuple of (*challengeId*: Token)
- SignInResult = TokenPair $\cup$ MfaChallenge

21.3.3 Exported Access Programs

Name	In	Out	Exceptions
init	-	-	-
hashPassword	*pw*: String	String	WeakPassword
signIn	*email*: String, *pw*: String, *dev*: DeviceID, *ip*: String	SignInResult	RateLimited, UnknownAccount, AccountLocked, InvalidCredentials
verifyMfa	*cid*: Token, *code*: String, *ip*: String	TokenPair	RateLimited, InvalidCode
refresh	*rt*: Token	TokenPair	Unauthenticated
authenticate	*tok*: Token, *ip*: String	Principal	Unauthenticated, RateLimited
authorize	*p*: Principal, *owner*: UserID	-	Forbidden
requireRole	*p*: Principal, *r*: Role	-	Forbidden
confirmPassword	*p*: Principal, *pw*: String	-	InvalidCredentials
signOut	*p*: Principal	-	-
endAllSessions	*u*: UserID	-	-
setMfaEnabled	*p*: Principal, *on*: $\mathbb{B}$	-	-
requestPasswordReset	*email*: String, *ip*: String	-	RateLimited
resetPassword	*t*: Token, *pw*: String	-	InvalidResetToken, WeakPassword

RateLimited carries the time the client must wait before its next request will be accepted.

21.4 Semantics

21.4.1 State Variables

- *sessions*: set of Session, where Session = tuple of (*id*: SessionID, *user*: UserID, *device*: DeviceID, *refreshHash*: String, *lastUsed*: Time, *revoked*: $\mathbb{B}$) (initially $\emptyset$)
- *failedAttempts*: UserID $\to \mathbb{Z}$, the number of consecutive failed sign-in attempts (initially 0)
- *lockedUntil*: UserID $\to$ Time, the time until which sign-in is locked (initially 0)
- *mfaEnabled*: UserID $\to \mathbb{B}$ (initially false)
- *challenges*: set of tuples of (*id*: Token, *user*: UserID, *device*: DeviceID, *codeHash*: String, *expires*: Time) (initially $\emptyset$)
- *resetTokens*: set of tuples of (*tokenHash*: String, *user*: UserID, *expires*: Time) (initially $\emptyset$)
- *requestLog*: String $\to$ sequence of Time, the times of recent requests, keyed by client IP address or by user ID
- *commonPasswords*: set of String, the common passwords that are rejected (SEC-ACC-04)

The initial values above apply when the system is first deployed. All state variables except *requestLog* and *commonPasswords* are stored through the Persistence Module, so they keep their values when the backend restarts. *requestLog* and *commonPasswords* are held in memory and are set by init.

21.4.2 Environment Variables

- *clock*: the system clock; *now*() returns the current Time.
- *signingKey*: the secret key used to sign access tokens. It is read from the deployment environment and is never stored in the project repository (SEC-ACC-03).
- *mailServer*: the outgoing email server used to send multi-factor authentication codes and password reset links.
- *securityLog*: sequence of tuples of (*time*: Time, *ip*: String $\cup\{\perp\}$, *event*: String, *user*: UserID $\cup\{\perp\}$), the log to which security events are written (SEC-AUD-02). Entries are only ever appended.
- *passwordFile*: the file listing common passwords, read by init.

21.4.3 Assumptions

- init is called once when the backend starts, before any other access program.
- Client–server communication uses TLS 1.3, configured when the backend is deployed (SEC-PRV-01). This module does not enforce it.
- The User and Onboarding Module ensures that email addresses are unique.
- Each client sends the same DeviceID on every request from a given installation.
- A single backend instance is running, so the in-memory *requestLog* counts every request. Running several instances would require a shared store.
- authenticate is called before any other backend access program on every protected request. Registration, signIn, verifyMfa, refresh, requestPasswordReset, resetPassword and the health check are the only unprotected requests.

21.4.4 Access Routine Semantics

The following apply to every access routine below.

- Request counting: each call to signIn, verifyMfa or requestPasswordReset first appends $now()$ to $requestLog(ip)$. In authenticate, once the token is verified, $now()$ is appended to $requestLog(p.user)$.
- Rate limits: when RateLimited is raised for key k, it carries $waitTime(k)$.
- Security log: every exception raised by this module, and every account lockout, appends the entry $(now(), ip, e, u)$ to *securityLog*. Here ip is the routine's ip input, or $\perp$ if it has none; e is the name of the exception, or LOCKOUT; and u is the user concerned, or $\perp$ if none is known. Passwords, codes and tokens are never written.
- An exception leaves the state unchanged apart from these entries, unless a transition for that exception is given.

init():

- transition:
  - *requestLog* := the mapping of every key to the empty sequence
  - *commonPasswords* := the passwords listed in *passwordFile*

hashPassword(pw):

- output: $out := hash(pw)$
- exception: $isWeak(pw) \Rightarrow$ WeakPassword

signIn($email, pw, dev, ip$):

- Let $a = \mathit{findUser}(email)$, $ok = \mathit{matches}(pw, a.\mathit{passwordHash})$, $rt = \mathit{newSecret}()$, $c = \mathit{newCode}()$, and $s = (\mathit{newId}(), a.id, dev, \mathit{digest}(rt), \mathit{now}(), \text{false})$.
- transition:
  - $ok \wedge \mathit{mfaEnabled}(a.id) \Rightarrow \mathit{failedAttempts}(a.id) := 0$. A new challenge with id $\mathit{newSecret}()$, user $a.id$, device dev, code hash $\mathit{hash}(c)$ and expiry $\mathit{now}() +$ MfaCodeExpiry is added to $\mathit{challenges}$. The code c is emailed to the user's address $a.\mathit{email}$ through the $\mathit{mailServer}$.
  - $ok \wedge \neg \mathit{mfaEnabled}(a.id) \Rightarrow \mathit{failedAttempts}(a.id) := 0$, $\mathit{sessions} := \mathit{sessions} \cup \{s\}$
  - When InvalidCredentials is raised, $\mathit{failedAttempts}(a.id)$ increases by 1. If it then equals LockoutAttempts, the account is locked: $\mathit{lockedUntil}(a.id) := \mathit{now}() +$ LockoutDuration and $\mathit{failedAttempts}(a.id) := 0$.
- output: $\mathit{out} := (\mathit{mfaEnabled}(a.id) \Rightarrow (\mathit{id} \text{ of the new challenge}) \mid \neg \mathit{mfaEnabled}(a.id) \Rightarrow (\mathit{issueAccess}(s), rt, \mathit{now}() + \mathsf{AccessExpiry}))$
- exception, with the cases checked in order:
  - $\mathit{overLimit}(ip) \Rightarrow$ RateLimited
  - $a = \bot \Rightarrow$ UnknownAccount
  - $\mathit{now}() < \mathit{lockedUntil}(a.id) \Rightarrow$ AccountLocked
  - $\neg ok \Rightarrow$ InvalidCredentials

verifyMfa($cid, code, ip$):

- Let h be the challenge in $\mathit{challenges}$ with $h.id = cid$, $rt = \mathit{newSecret}()$, and $s = (\mathit{newId}(), h.\mathit{user}, h.\mathit{device}, \mathit{digest}(rt), \mathit{now}(), \text{false})$.
- transition: $\mathit{challenges} := \mathit{challenges} - \{h\}$, $\mathit{sessions} := \mathit{sessions} \cup \{s\}$
- output: $\mathit{out} := (\mathit{issueAccess}(s), rt, \mathit{now}() + \mathsf{AccessExpiry})$
- exception: $\mathit{overLimit}(ip) \Rightarrow$ RateLimited $\mid$ h does not exist $\vee$ $\mathit{now}() > h.\mathit{expires} \vee \neg \mathit{matches}(code, h.\mathit{codeHash}) \Rightarrow$ InvalidCode

refresh(rt):

- Let s be the session in $\mathit{sessions}$ with $\neg s.\mathit{revoked} \wedge s.\mathit{refreshHash} = \mathit{digest}(rt)$, and $rt' = \mathit{newSecret}()$.
- transition: $s.\mathit{refreshHash}, s.\mathit{lastUsed} := \mathit{digest}(rt'), \mathit{now}()$. The old refresh token can no longer be used.

- output: $out := (\mathit{issueAccess}(s), rt', \mathit{now}() + \mathsf{AccessExpiry})$
- exception: s does not exist $\lor\ \mathit{now}() - s.\mathit{lastUsed} > \mathsf{SessionTimeout} \Rightarrow$ Unauthenticated

authenticate($\mathit{tok}, \mathit{ip}$):

- Let $p = \mathit{verifyAccess}(\mathit{tok})$ and s be the session in $\mathit{sessions}$ with $s.\mathit{id} = p.\mathit{session}$.
- output: $\mathit{out} := p$
- exception, with the cases checked in order:
  - $p = \bot \lor s.\mathit{revoked} \Rightarrow$ Unauthenticated
  - $\mathit{overLimit}(p.\mathit{user}) \Rightarrow$ RateLimited

authorize(p, owner):

- exception: $p.\mathit{user} \neq \mathit{owner} \Rightarrow$ Forbidden

requireRole(p, r):

- exception: $p.\mathit{role} \neq r \Rightarrow$ Forbidden

confirmPassword(p, pw):

- exception: $\neg \mathit{matches}(\mathit{pw}, \mathit{account}(p.\mathit{user}).\mathit{passwordHash}) \Rightarrow$ InvalidCredentials

signOut(p):

- transition: $s.\mathit{revoked} :=$ true for the session s with $s.\mathit{id} = p.\mathit{session}$. Every access and refresh token issued for that session, and so for that device, is rejected from then on.

endAllSessions(u):

- transition: $s.\mathit{revoked} :=$ true for every $s \in \mathit{sessions}$ with $s.\mathit{user} = u$; $\mathit{challenges} := \{h \in \mathit{challenges} \mid h.\mathit{user} \neq u\}$; $\mathit{resetTokens} := \{r \in \mathit{resetTokens} \mid r.\mathit{user} \neq u\}$

setMfaEnabled(p, on):

- transition: $\mathit{mfaEnabled}(p.\mathit{user}) := \mathit{on}$

requestPasswordReset($\mathit{email}, \mathit{ip}$):

- Let $a = \mathit{findUser}(\mathit{email})$ and $t = \mathit{newSecret}()$.
- transition:
  - $a \neq \bot \Rightarrow$ the reset token $(\mathit{digest}(t), a.\mathit{id}, \mathit{now}() + \mathsf{ResetTokenExpiry})$ is added to $\mathit{resetTokens}$, and a link containing t is emailed to $a.\mathit{email}$ through $\mathit{mailServer}$
  - $a = \bot \Rightarrow$ no change

- output: none in either case
- exception: $overLimit(ip) \Rightarrow$ RateLimited

resetPassword(t, pw):

- Let r be the reset token in *resetTokens* with $r.tokenHash = digest(t)$.
- transition:
  - $account(r.user).passwordHash := hash(pw)$
  - $failedAttempts(r.user) := 0$ and $lockedUntil(r.user) := 0$, so a locked-out user can sign in again
  - the transition of endAllSessions$(r.user)$, which also removes r so the link cannot be used again
- exception: r does not exist $\vee$ $now() > r.expires \Rightarrow$ InvalidResetToken | $isWeak(pw) \Rightarrow$ WeakPassword

21.4.5 Local Functions

- UserRecord = tuple of (*id*: UserID, *email*: String, *role*: Role, *passwordHash*: String)
- *findUser*: String $\to$ UserRecord $\cup\{\bot\}$
  $findUser(e) \equiv$ the stored user record whose email is e, read through the Persistence Module, or $\bot$ if there is none.
- *account*: UserID $\to$ UserRecord
  $account(u) \equiv$ the stored user record whose id is u, read and written through the Persistence Module.
- *isWeak*: String $\to \mathbb{B}$
  $isWeak(pw) \equiv |pw| <$ MinPasswordLength $\vee$ $pw \in commonPasswords$
- *hash*: String $\to$ String
  A deliberately slow, salted one-way hash using a new random salt on each call. It is used for passwords and multi-factor authentication codes.
- *matches*: String $\times$ String $\to \mathbb{B}$
  $matches(x, h) \equiv h$ is the result of $hash(x)$ under the salt stored in h.
- *digest*: String $\to$ String
  A fast, unsalted one-way hash. It is used only for long random values produced by *newSecret*, so that a stored value can be looked up from the token the client presents.

- *newSecret*: $\rightarrow$ Token
  A random value of at least 256 bits from a cryptographically secure random number generator.

- *newCode*: $\rightarrow$ String
  A random six-digit code from a cryptographically secure random number generator.

- *newId*: $\rightarrow \mathbb{N}$
  An identifier not used by any existing session.

- *issueAccess*: Session $\rightarrow$ Token
  $issueAccess(s) \equiv$ a token containing $s.user$, $account(s.user).role$, $s.id$, $s.device$ and the expiry time $now() + \mathsf{AccessExpiry}$, signed with $signingKey$.

- *verifyAccess*: Token $\rightarrow$ Principal $\cup\{\bot\}$
  $verifyAccess(t) \equiv \bot$ if t is missing, its signature does not match $signingKey$, or its expiry time is not after $now()$; otherwise the Principal contained in t.

- *overLimit*: String $\rightarrow \mathbb{B}$
  $overLimit(k) \equiv |\langle x \in requestLog(k) \mid x > now() - 60 \rangle| > \mathsf{RateLimit}$

- *waitTime*: String $\rightarrow \mathbb{R}$
  $waitTime(k) \equiv$ the smallest number of seconds $w \geq 0$ for which $requestLog(k)$ has fewer than RateLimit entries later than $now() + w - 60$. A request for k made w seconds from now is accepted.

22 Appendix — Generative AI Use Disclosure

[ChatGPT (version 5) was used to brainstorm ideas for the template for this disclose section. —SS]

22.1 AI Tools Used

[Give the name of the AI tool(s) used and the version. —SS]

22.2 How and Where Used

[Explain what the tool(s) were used for. Examples include: brainstorming, explaining a technical concept, reviewing the document, generating or modifying text, generating or modifying diagrams, identifying errors or omissions or inconsistencies. —SS]

[For each of the uses, identify which parts of the document were affected. —SS]

[You do not need to report every interaction, but you should disclose the uses that materially contributed to your work —SS]

22.3 Verification of AI-Generated Content

[

- Describe how the team checked AI-generated or AI-assisted material before including it in the document.
- In particular, verify factual claims, technical assertions, requirements, calculations, references, and other information for which an AI system may produce incorrect or fabricated results.
- **The team is responsible for the accuracy, completeness, consistency, and appropriateness of the submitted document, regardless of whether material was generated by a human or an AI system.**

—SS]

23 Appendix — Reflection

[Not required for CAS 741 projects —SS]

The information in this section will be used to evaluate the team members on the graduate attribute of Problem Analysis and Design.

The purpose of reflection questions is to give you a chance to assess your own learning and that of your group as a whole, and to find ways to improve in the future. Reflection is an important part of the learning process. Reflection is also an essential component of a successful software development process.

Reflections are most interesting and useful when they're honest, even if the stories they tell are imperfect. You will be marked based on your depth of thought and analysis, and not based on the content of the reflections themselves. Thus, for full marks we encourage you to answer openly and honestly and to avoid simply writing "what you think the evaluator wants to hear."

Please answer the following questions. Some questions can be answered on the team level, but where appropriate, each team member should write their own response:

1. What went well while writing this deliverable?
2. What pain points did you experience during this deliverable, and how did you resolve them?
3. Which of your design decisions stemmed from speaking to your client(s) or a proxy (e.g. your peers, stakeholders, potential users)? For those that were not, why, and where did they come from?
4. While creating the design doc, what parts of your other documents (e.g. requirements, hazard analysis, etc), it any, needed to be changed, and why?

5. What are the limitations of your solution? Put another way, given unlimited resources, what could you do to make the project better? (LO_ProbSolutions)

6. Give a brief overview of other design solutions you considered. What are the benefits and tradeoffs of those other designs compared with the chosen design? From all the potential options, why did you select the documented design? (LO_Explores)

7. (After you have implemented another team's module, which means this isn't filled in until after the original deadline). What did you learn by implementing another team's module? Were all the details you needed in the documentation, or did you need to make assumptions, or ask the other team questions? If your team also had another team implement one of your modules, what was this experience like? Are there things in your documentation you could have changed to make the process go more smoothly for when an "outsider" completes some of the implementation?

   Your reflection should be about concepts learned in your SE education, such as modular decomposition, cohesion, coupling, information hiding, etc. You should critique the quality and utility of the specification you received.

   You should create a PR for your implemented module. A link to the PR should be part of your reflection.